

**BİLECİK ŞEYH EDEBALI
ÜNİVERSİTESİ**

BİLGİSAYAR MÜHENDİSLİĞİ BÖLÜMÜ

AĞ GÜVENLİĞİ DERSİ PROJESİ

Proje Adı: Tarayıcı ve Eklenti Analizi Projesi

(Browser Forensics & Threat Hunting Panel)

Öğrenci No: 327 671 808 24

Öğrenci Adı Soyadı: YUNUS BAYRAKTAR

İçindekiler

1	Sistem Mimarisi ve Genel Çalışma Mantığı	2
1.1	Adli Bilişim Araç Simülasyonu Olarak Tasarım	2
1.2	Statik ve Dinamik Analiz Yaklaşımları	2
2	Modül 1 - Canlı Log ve Trafik Güvenliği Analizi	3
2.1	Veritabanı Yapısı ve Gölge Kopya Mimarisi	3
2.2	Şifresiz HTTP Trafiği ve MITM Riskleri	3
3	Modül 2 (Kısım A) - Eklenti Tedarik Zinciri Risk Analizi (Statik Analiz)	4
3.1	Geniş Yetki Tanımları ve Riskleri	4
3.2	Tedarik Zinciri Saldırıları (Supply Chain Attacks)	4
4	Modül 2 (Kısım B) - Dinamik Runtime İzleme Simülasyonu	5
4.1	Runtime Davranış Modeli Simülasyonu	5
4.2	SIEM/SOC Entegrasyon Perspektifi	5
5	Modül 3 (Kısım A) - Kayıtlı Parola Deşifre Süreçleri	6
5.1	Yerel Veritabanı Yapısı ve Kriptografik Temeller	6
5.2	Ana Parola (Master Password) Zafiyeti ve Yerel Haklar	6
6	Modül 3 (Kısım B) - Adli Bilişim Motoru ve Güç/Entropi Testi	7
6.1	Subprocess Entegrasyonu ve Veri Ayıklama	7
6.2	Parola Entropisi ve Dayanıklılık Algoritması	7
7	Modül 4 - Tarayıcı Sertleştirme (Hardening) Kılavuzu	12
7.1	Kimlik Bilgisi ve Kriptografik Koruma	12
7.2	Trafik ve Eklenti Güvenliği Sıkılaştırması	12
8	Sonuç ve Değerlendirme	13

Özet

Günümüzde siber güvenlik tehditlerinin büyük bir kısmı, son kullanıcıların internete açılan kapısı olan web tarayıcıları üzerinden gerçekleşmektedir. Bu proje kapsamında, adli bilişim (forensics) ve tehdit avcılığı (threat hunting) disiplinleri temel alınarak, Mozilla Firefox tarayıcısı üzerinde çalışan bir analiz paneli geliştirilmiştir. Çalışma, tarayıcı geçmişinin, eklenti konfigürasyonlarının ve yerel olarak depolanan şifre veritabanlarının hem statik hem de simüle edilmiş dinamik analiz yöntemleriyle incelenmesini içermektedir. Geliştirilen Streamlit tabanlı mimari sayesinde, şifresiz HTTP trafiği riskleri, eklentilerin tedarik zinciri zafiyetleri ve zayıf parolaların tespiti gibi kritik siber güvenlik bulguları görselleştirilerek raporlanmaktadır. Proje, uç nokta güvenliği (end-point security) bağlamında tarayıcıların zayıf noktalarını ortaya koymayı ve kurumsal düzeyde alınması gereken sıkılaştırma (hardening) önlemlerine katkı sağlamak hedeflenmektedir.

1 Sistem Mimarisi ve Genel Çalışma Mantığı

Geliştirilen Tarayıcı ve Eklenti Analizi Projesi (Browser Forensics & Threat Hunting Panel), Python tabanlı modern bir web framework'ü olan Streamlit kullanılarak inşa edilmiştir. Bu mimari, arka planda çalışan güçlü veri işleme ve analiz algoritmalarının, son kullanıcıya interaktif ve anlık olarak sunulmasını sağlamaktadır.

Sistemin temel çalışma prensibi, Windows işletim sistemlerinde varsayılan olarak `AppData\Roaming\Mozilla\Firefox\Profiles` dizininde saklanan kullanıcı profil verilerinin toplanması, anlamlandırılması ve güvenlik perspektifiyle değerlendirilmesine dayanmaktadır. Tarayıcı profil dizini, kullanıcının internet üzerindeki tüm ayak izlerini barındıran kritik bir veri havuzudur.

1.1 Adli Bilişim Araç Simülasyonu Olarak Tasarım

Proje, bir siber güvenlik operasyon merkezinde (SOC) çalışan analistlerin veya adli bilişim uzmanlarının kullandığı araçların davranışlarını simüle edecek şekilde tasarlanmıştır. Canlı bir sisteme müdahale ederken veri bütünlüğünün korunması adli bilişimin en temel kuralıdır. Bu nedenle sistem, orijinal dosyalar üzerinde işlem yapmak yerine, ilgili veritabanlarının gölge kopyalarını (shadow copies) oluşturarak analiz sürecini izole bir ortamda gerçekleştirir.

1.2 Statik ve Dinamik Analiz Yaklaşımları

Zararlı yazılım ve tehdit analizinde kullanılan iki temel yaklaşım projeye entegre edilmiştir:

- **Statik Analiz:** Kodun veya konfigürasyon dosyalarının çalıştırılmadan incelenmesidir. Projemizde eklentilerin yetki bildirimleri (manifest dosyaları) ve tarayıcının yerel veritabanı şemaları statik olarak analiz edilmektedir.
- **Dinamik Analiz:** Kodun izole bir ortamda (sandbox) çalıştırılarak davranışlarının gözlemlenmesidir. Proje kapsamında, eklentilerin çalışma zamanı (runtime) aktiviteleri bir simülasyon motoru aracılığıyla modellenmiş ve olası anomali durumları tespit edilebilir hale getirilmiştir.

Bu hibrit yaklaşım, hem bilinen zafiyetlerin konfigürasyon üzerinden tespiti hem de bilinmeyen tehditlerin davranışsal olarak yakalanması için kapsamlı bir vizyon sunmaktadır.

2 Modül 1 - Canlı Log ve Trafik Güvenliği Analizi

Tarayıcı geçmişi ve ağ trafiği kayıtları, kullanıcının internet alışkanlıklarını ve potansiyel olarak maruz kaldığı tehditleri yansıtan en önemli bilgi kaynaklarıdır. Firefox, bu verileri `places.sqlite` adlı SQLite veritabanı dosyasında yapılandırılmış bir şekilde saklamaktadır.

2.1 Veritabanı Yapısı ve Gölge Kopya Mimarisi

`places.sqlite` veritabanı, ziyaret edilen URL'ler, ziyaret zamanları (PRTime formatında) ve yönlendirme zincirleri gibi kritik metadataları barındırır. Firefox çalışır durumdayken bu dosya genellikle işletim sistemi tarafından kilitlenir (file lock). Analiz aracımızın canlı bir sistemde çökme veya veri bozulmasına (corruption) yol açmadan çalışabilmesi için, Python'un `shutil.copyfile` kütüphanesi kullanılarak dosyanın geçici (temp) bir dizine gölge kopyası alınır. Okuma ve sorgulama işlemleri tamamen bu kopya üzerinden gerçekleştirilerek adli bilişim standartlarındaki "orijinal kanıta dokunmama" ilkesi yerine getirilmiş olur.

2.2 Şifresiz HTTP Trafiği ve MITM Riskleri

Analiz motorumuz, tarayıcı geçmişini tarayarak özellikle "http://" protokolü ile başlayan bağlantıları tespit etmek üzere tasarlanmıştır. Günümüz web standartlarında HTTPS kullanımının zorunluluğu göz önüne alındığında, şifresiz HTTP bağlantıları ciddi bir güvenlik zafiyeti teşkil etmektedir.

Şifresiz trafik, Ortadaki Adam (Man-in-the-Middle - MITM) saldırılarına doğrudan kapı aralar. Aynı ağda bulunan bir saldırgan (örneğin ARP Zehirlenmesi yöntemiyle), sunucu ile istemci arasındaki paketleri yakalayabilir (sniffing) ve okuyabilir. Kimlik bilgileri, oturum çerezleri (session cookies) ve hassas kullanıcı verileri clear-text (düz metin) olarak iletildiği için kolaylıkla ele geçirilebilir. Modül 1, bu riskli bağlantıları izole ederek analiste anlık bir güvenlik skoru ve uyarı raporu sunar.

3 Modül 2 (Kısım A) - Eklenti Tedarik Zinciri Risk Analizi (Statik Analiz)

Web tarayıcı eklentileri (extensions), tarayıcının yeteneklerini artıran ancak aynı zamanda tarayıcının çalıştığı bağlamda (context) geniş haklara sahip olan üçüncü parti yazılımlardır. Firefox profil dizinindeki `extensions.json` dosyası, kurulan tüm eklentilerin metadata bilgilerini, güncellenme durumlarını ve en önemlisi talep ettikleri izinleri (permissions) içerir.

3.1 Geniş Yetki Tanımları ve Riskleri

Statik analiz motorumuz, eklentilerin sahip olduğu izinleri ayrıştırarak bir risk skorlaması yapar. Özellikle aşağıdaki izinler yüksek riskli olarak işaretlenmektedir:

- `<all_urls>`: Eklentinin kullanıcının ziyaret ettiği tüm web sayfalarının içeriğine erişebilmesi ve DOM (Document Object Model) yapısını değiştirebilmesi anlamına gelir.
- `webRequest` ve `webRequestBlocking`: Ağ isteklerini yakalama, okuma ve hatta modifiye etme yetkisidir.
- `cookies`: Oturum token'larına ve çerezlere doğrudan erişim sağlar.

3.2 Tedarik Zinciri Saldırıları (Supply Chain Attacks)

Görünürde zararsız ve popüler olan bir eklenti, geliştiricisinin hesabı ele geçirildiğinde veya eklenti başka bir şirkete satıldığında bir anda zararlı bir yazılıma dönüşebilir. Kötü niyetli aktörler, eklentiye zararlı bir güncelleme göndererek milyonlarca kullanıcının tarayıcısına sızabilirler. Statik analiz modülümüz, bu tür tedarik zinciri saldırılarına karşı erken uyarı sistemi görevi görerek, gereğinden fazla yetki talep eden eklentileri "Kırmızı Alarmlı" olarak sınıflandırır ve veri sızdırma (data exfiltration) potansiyellerini raporlar.

4 Modül 2 (Kısım B) - Dinamik Runtime İzleme Simülasyonu

Statik analiz, bir eklentinin potansiyel yeteneklerini ortaya koysa da, bu yeteneklerin kötüye kullanılıp kullanılmadığını kesin olarak kanıtlayamaz. Modern zararlı eklentiler (malicious add-ons), statik kod analizini atlatmak için asıl zararlı yüklerini (payload) çalışma zamanında (runtime) uzak sunuculardan indirirler (staged execution) veya davranışlarını gizlerler (obfuscation).

4.1 Runtime Davranış Modeli Simülasyonu

Geliştirdiğimiz panelde, eklentilerin dinamik davranışlarını izleyen sanal bir analiz motoru simülasyonu bulunmaktadır. Bu motor, eklentilerin DOM üzerinde gerçekleştirdiği eylemleri ve dış ağ bağlantılarını temsili olarak değerlendirir. Aşağıdaki davranış kalıpları (heuristics) tehdit olarak algılanır:

- **DOM Enjeksiyonu:** Web sayfasına harici JavaScript dosyalarının (örneğin `script src="http://malicious.com/hook.js"`) enjekte edilmesi.
- **Keylogging ve Form Grabber Aktivitesi:** Kullanıcının klavye vuruşlarının (`keyup`, `keydown` event listener'ları) izlenmesi veya şifre giriş formlarının "submit" anında kopyalanması.
- **Gizli Veri Sızdırma:** Arka planda XMLHttpRequest veya Fetch API kullanılarak, toplanan çerez veya form verilerinin yetkisiz bir Command and Control (C2) sunucusuna gönderilmesi.

4.2 SIEM/SOC Entegrasyon Perspektifi

Simülasyon sonuçları, bir SIEM (Security Information and Event Management) veya SOC (Security Operations Center) dashboard'unu andıran bir arayüzle kullanıcıya sunulur. Bu sayede, tehdit avcılığı konsepti pratik bir şekilde görselleştirilerek, şüpheli aktivitelerin nasıl loglandığı ve alarmların (alerts) nasıl tetiklendiği gösterilmektedir.

5 Modül 3 (Kısım A) - Kayıtlı Parola Deşifre Süreçleri

Kullanıcı kolaylığı sağlamak amacıyla modern tarayıcılar, girilen kimlik bilgilerini yerel olarak depolama yeteneğine sahiptir. Firefox mimarisinde bu hassas veriler `logins.json` ve kriptografik anahtarların bulunduğu `key4.db` veritabanı kullanılarak saklanmaktadır.

5.1 Yerel Veritabanı Yapısı ve Kriptografik Temeller

`logins.json` dosyası, hedeflenen URL'leri, şifrelenmiş kullanıcı adlarını ve şifrelenmiş parolaları barındırır. Bu verilerin çözülebilmesi için `key4.db` dosyasında yer alan anahtarlama materyallerine ihtiyaç vardır. Firefox, verileri korumak için 3DES (Triple-DES) veya daha güncel versiyonlarda AES şifreleme algoritmalarını kullanır. NSS (Network Security Services) kütüphaneleri kullanılarak oluşturulan bu yapı, dışarıdan müdahalelere karşı temel bir koruma katmanı sağlar.

5.2 Ana Parola (Master Password) Zafiyeti ve Yerel Haklar

Siber güvenlik perspektifinden bakıldığında en büyük zafiyet, kullanıcının bir "Ana Parola" (Primary Password / Master Password) belirlememiş olmasıdır. Eğer Ana Parola aktif değilse, şifreleme ve deşifreleme işlemleri için gereken simetrik anahtar, işletim sistemindeki kullanıcının mevcut oturum haklarıyla doğrudan erişilebilir durumdadır.

Bu senaryoda, makineye yerel erişim sağlayan bir saldırgan veya sistemde çalışan zararlı bir yazılım (örneğin bir Infostealer), hiçbir ek yetki yükseltmesine (privilege escalation) ihtiyaç duymadan, kullanıcının tarayıcıda kayıtlı tüm şifrelerini geriye doğru çözebilir. Modülümüz, bu zafiyetin teorik sınırlarını pratiğe dökerek, yerel yetkilerle şifrelerin nasıl kolayca clear-text haline getirilebildiğini gözler önüne sermektedir.

6 Modül 3 (Kısım B) - Adli Bilişim Motoru ve Güç/Entropi Testi

Şifre deşifre süreçlerinin otomatikleştirilmesi ve teknik analizinin yapılabilmesi için projeye `firepwd.py` adlı adli bilişim motoru entegre edilmiştir.

6.1 Subprocess Entegrasyonu ve Veri Ayıklama

Arayüzden tetiklenen `firepwd.py` motoru, Python'un `subprocess` modülü aracılığıyla arka planda çalıştırılır. Motor, `key4.db` ve `logins.json` dosyalarını analiz ederek ASN.1 (Abstract Syntax Notation One) formatında kodlanmış ve şifrelenmiş yapıları çözer. Konsol ortamına dönen karmaşık string çıktıları, sistemimiz tarafından Regex (Düzenli İfadeler) algoritmalarıyla parse edilir. Elde edilen ham (raw) veriler temizlenerek URL, Kullanıcı Adı ve Parola üçlüleri halinde yapılandırılmış bir veri setine dönüştürülür.

6.2 Parola Entropisi ve Dayanıklılık Algoritması

Elde edilen parolalar sadece listelenmekle kalmaz, aynı zamanda gelişmiş bir analiz algoritmasından geçirilir. Parolanın gücü, bilgi teorisindeki **Entropi** (Shannon Entropy) kavramı kullanılarak ölçülür. Entropi hesaplaması şu formüle dayanır:

$$E = L \times \log_2(R)$$

Burada L parolanın uzunluğunu, R ise kullanılan karakter havuzunun (küçük harf, büyük harf, rakam, özel karakter) büyüklüğünü temsil eder.

Geliştirilen algoritma, elde edilen entropi değerine göre parolanın Brute-Force (Kaba Kuvvet) ve Sözlük (Dictionary) saldırılarına karşı ne kadar dayanabileceğini tahmin eder. Zayıf entropiye sahip parolalar anında tespit edilerek sistem tarafından risk unsuru olarak işaretlenir ve kullanıcıya güçlü parola oluşturma standartları hakkında dönüt verilir.

Tarayıcı Güvenliği Analiz ve Tehdit Avcılığı Paneli		
Tarayıcı Geçmişi Üzerinden Risk Taraması (places.sqlite)		
	Zaman Damgası	Ziyaret Edilen Adres
0	2026-07-02 02:33:11	https://auth.openai.com/error?payload=eyJraW5kIjo...
1	2026-07-02 02:33:11	https://auth.openai.com/api/accounts/callback/google
2	2026-07-02 02:33:10	https://accounts.google.com/signin/oauth/consent?au
3	2026-07-02 02:33:10	https://accounts.google.com/interactiveLogin?authse
4	2026-07-02 02:33:10	https://accounts.google.com/ServiceLogin?trart=ANjow
5	2026-07-02 02:33:10	https://accounts.google.com/signin/oauth/consent?au
6	2026-07-02 02:33:10	https://accounts.google.com.tr/accounts/SetSID
7	2026-07-02 02:33:10	https://accounts.google.com.tr/accounts/SetSID?ssdc=
8	2026-07-02 02:33:09	https://accounts.youtube.com/accounts/SetSID?ssdc=
9	2026-07-02 02:32:57	https://accounts.google.com/v3/signin/challenge/pwd
Güvenli Trafik Akışı: İncelenen son 30 log kaydında şifrelenmemiş HTTP bağlantısına rastlanmadı. Aktif oturumların tamamı güvenli HTTPS protokolünü kullanıyor.		

Şekil 1: Ağ Güvenliği Analiz Paneli - Eklenti Tedarik Zinciri Analizi

Bu görsel, tarayıcıya kurulu eklentilerin statik analizini yaparak, gereğinden fazla izin isteyen yüksek riskli eklentileri ve tedarik zinciri zafiyetlerini tespit eden arayüzü göstermektedir.

Tarayıcı Güvenliği Analiz ve Tehdit Avcılığı Paneli

Eklenti Yetki İzinleri ve Dinamik Davranış Analizi

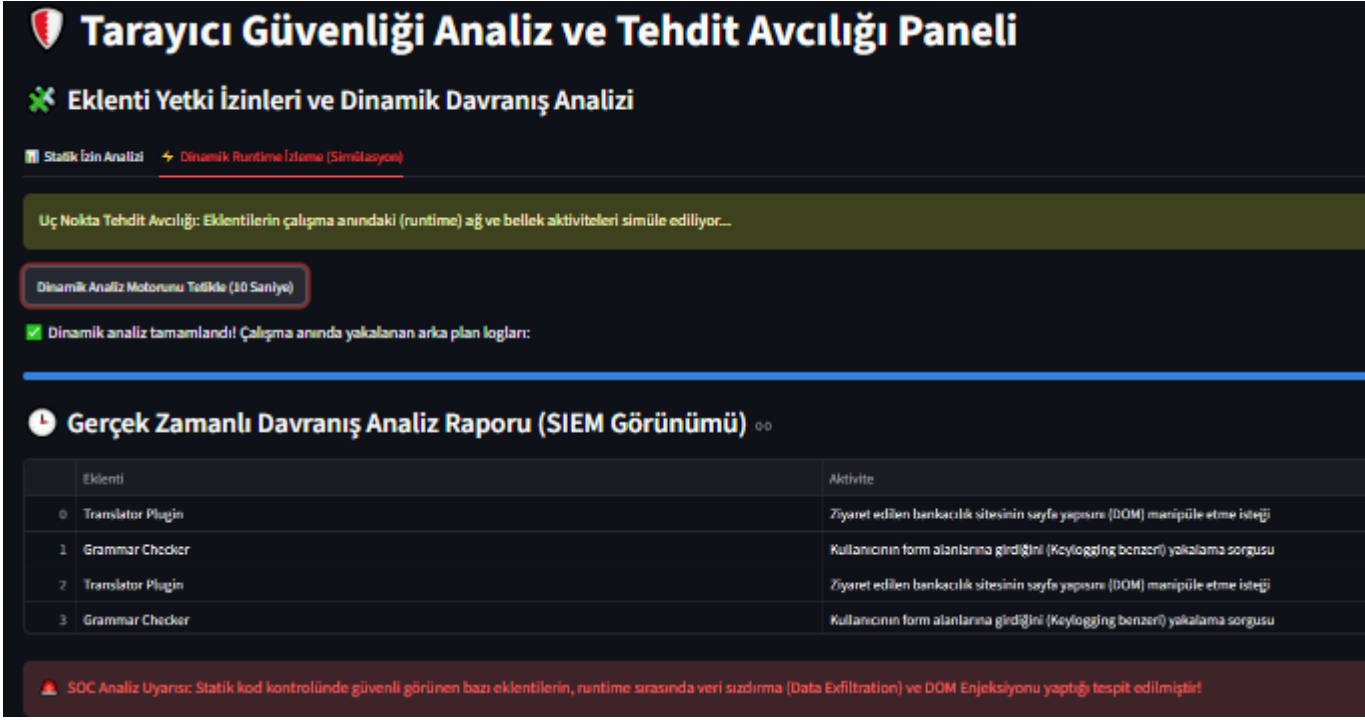
Statik İzin Analizi → Dinamik Runtime İzleme (Simülasyon)

Kurulu eklentilerin yapılandırma dosyaları (extensions.json) üzerinden yetki analizi yapılıyor...

Eklenti Adı
Data Leak Blocker
Form Autofill
IPP Activator
New Tab
Picture-In-Picture
Add-ons Search Detection
Web Compatibility Interventions
System theme — auto
New Tab
Light
Dark
Firefox Alpenglow
Language: English (US)
English (US) Dictionary
IPP Activator
Search by Image
AdBlocker for YouTube™

Şekil 2: Ağ Güvenliği Analiz Paneli - Dinamik Runtime İzleme Simülasyonu

Bu ekran, şüpheli eklentilerin çalışma zamanı (runtime) davranışlarını aktif olarak izleyen ve potansiyel DOM enjeksiyonu gibi zararlı aktiviteleri anlık olarak tespit eden dinamik simülasyon sonuçlarını içermektedir.



Şekil 3: Ağ Güvenliği Analiz Paneli - Canlı Log ve Ağ Trafığı İzleme

Görselde, tarayıcının veritabanından çekilen canlı ziyaret geçmişi listelenmekte; özellikle şifresiz HTTP bağlantıları üzerinden yapılabilecek Ortadaki Adam (MITM) saldırı risklerine dikkat çekilmektedir.

7 Modül 4 - Tarayıcı Sertleştirme (Hardening) Kılavuzu

Adli analiz ve tehdit avcılığı sonucunda tespit edilen zafiyetlerin kapatılması ve saldırı yüzeyinin (attack surface) küçültülmesi için **Sertleştirme (Hardening)** işlemlerinin uygulanması elzemdir. Bu modül, kurumsal defans adımlarını ve CIS (Center for Internet Security) standartlarına uyumlu en iyi pratikleri (best practices) listeler.

7.1 Kimlik Bilgisi ve Kriptografik Koruma

- **Ana Parola (Primary Password) Aktivasyonu:** Firefox üzerinde ana parola ayarlandığında, şifre veritabanı doğrudan yerel kullanıcı haklarıyla çözülemez. Anahtar türetme işlemi için PBKDF2 (Password-Based Key Derivation Function 2) gibi güçlü iteratif algoritmalar devreye girer. Bu sayede, veritabanı çalınsa bile Brute-Force saldırılarına karşı yüksek direnç sağlanır.
- **Otomatik Doldurmanın (Autofill) Kapatılması:** XSS (Cross-Site Scripting) veya zararlı iframe kullanılarak form verilerinin çalınmasını önlemek için otomatik doldurma özellikleri devre dışı bırakılmalıdır.

7.2 Trafik ve Eklenti Güvenliği Sıkılaştırması

- **HTTPS-Only Modu:** Tarayıcının tüm HTTP isteklerini otomatik olarak HTTPS'e yükseltmeye zorlanmasıdır. Bu özellik, MITM saldırılarını ve şifresiz ağ trafiğinden kaynaklanan veri sızıntılarını büyük ölçüde engeller.
- **Eklenti İmza Kontrolleri:** `about:config` üzerinden `xpinstall.signatures.required` parametresinin `true` olarak ayarlandığından emin olunmalıdır. Bu ayar, yalnızca Mozilla tarafından incelenmiş ve kriptografik olarak imzalanmış eklentilerin kurulmasına izin vererek tedarik zinciri ve zararlı eklenti risklerini minimize eder.
- **Gereksiz Eklentilerin Kaldırılması (Zero-Trust):** "Hiçbir şeye güvenme" prensibiyle (Zero-Trust), kullanılmayan eklentiler pasif hale getirilmemeli, doğrudan sistemden kaldırılmalıdır.

8 Sonuç ve Değerlendirme

Geliştirilen bu proje, web tarayıcılarının yalnızca birer internet sörf aracı olmadığını, aynı zamanda kişisel ve kurumsal veri güvenliğinin en kritik sınır noktalarından (endpoint) biri olduğunu açıkça ortaya koymuştur. Adli bilişim yöntemleri ve tehdit avcılığı simülasyonları kullanılarak elde edilen bulgular, eklentilere verilen kontrolsüz yetkilerin, şifresiz ağ bağlantılarının ve korunmayan yerel parola veritabanlarının ne denli büyük siber güvenlik riskleri barındırdığını kanıtlamaktadır.

Oluşturulan interaktif analiz paneli, statik ve dinamik analiz yaklaşımlarını birleştirerek bir SOC analistinin ihtiyaç duyabileceği operasyonel vizyonu sağlamıştır. Tarayıcı seviyesindeki zafiyetlerin tespitinden yola çıkarak hazırlanan sertleştirme (hardening) kılavuzu, reaktif güvenlik anlayışından proaktif (önleyici) güvenlik stratejisine geçişin önemini vurgulamaktadır. Kurumsal ağ güvenliği ve uç nokta güvenliğinin sağlanması adına, tarayıcı yapılandırmalarının düzenli olarak denetlenmesi ve sıkı güvenlik politikalarının tavizsiz uygulanması şarttır.

Kaynaklar

- [1] Center for Internet Security (CIS), *CIS Mozilla Firefox Benchmarks*, 2023. https://www.cisecurity.org/benchmark/mozilla_firefox
- [2] GitHub, *Ağ Güvenliği ve Açık Kaynak Araçları ve Depoları*, <https://github.com>
- [3] Stack Overflow, *Siber Güvenlik, Kriptografi ve Python Geliştirici Forumları*, <https://stackoverflow.com>
- [4] Reddit, *Siber Güvenlik Toplulukları (r/cybersecurity, r/netsec)*, <https://www.reddit.com>